

THIRD-PARTY VENDOR RISK ASSESSMENT

Salesforce CRM Platform - Government Contractor Suitability Review

Prepared for: CISO, Apex Defense Solutions | Classification: CONFIDENTIAL

1. Assessment Metadata

Assessment Title	Third-Party Vendor Risk Assessment - Salesforce CRM Platform
Assessment ID	TPRM-2026-0519-001
Date of Assessment	May 19, 2026
Analyst	Bryan Sykes, GRC Analyst
Requesting Organization	Apex Defense Solutions (Fictional Government Contractor)
Vendor Name	Salesforce, Inc.
Vendor Website	salesforce.com trust.salesforce.com
Vendor Headquarters	Salesforce Tower, 415 Mission Street, San Francisco, CA 94105
Product Being Assessed	Salesforce CRM Platform (Sales Cloud / Service Cloud)
Assessment Method	Publicly available trust center documentation, compliance certificates, and security attestations reviewed via trust.salesforce.com
Applicable Frameworks	FedRAMP, CMMC 2.0, NIST SP 800-171, NIST SP 800-53, DoD IL4/IL5
Classification	CONFIDENTIAL - Internal Use Only

2. Organizational Context

2.1 Assessing Organization Profile

Apex Defense Solutions is a fictional, mid-size government contractor providing systems integration, cybersecurity consulting, and program management services to federal defense and intelligence agencies. The organization holds active contracts with the Department of Defense (DoD) and processes Controlled Unclassified Information (CUI) in the execution of contract deliverables. As a DoD contractor, Apex Defense Solutions is subject to CMMC 2.0 certification requirements and must ensure all third-party vendors that process, store, or transmit CUI on its behalf meet equivalent security standards.

2.2 Purpose of This Assessment

Apex Defense Solutions is evaluating Salesforce as a CRM platform to manage customer relationships, contract pipelines, and stakeholder communications. Given the nature of the data that may flow through the CRM including federal agency contact information, contract data, and

potentially CUI. This assessment is required before any procurement decision can be made. The assessment evaluates Salesforce's security posture, compliance certifications, and suitability for use in a government contractor environment subject to FedRAMP and CMMC requirements.

2.3 Data Classification Considerations

The following data types have been identified as likely to be processed within the Salesforce CRM environment if deployed at Apex Defense Solutions:

- Federal agency point-of-contact information and communication records
- Contract opportunity data and pipeline information
- Proposal development notes and competitive intelligence
- Potentially CUI if contract management workflows are integrated into the CRM

The presence of potential CUI in the CRM environment elevates this assessment from a standard SaaS vendor review to a government-sensitive procurement decision requiring FedRAMP authorization verification and CMMC alignment confirmation.

3. Vendor Overview

Company Name	Salesforce, Inc.
Founded	1999 - San Francisco, CA
Company Type	Public corporation (NYSE: CRM) S&P 500 constituent
Annual Revenue	Approximately \$37 billion (FY2025)
Employees	Approximately 72,000 globally
Primary Business	Cloud-based CRM, sales automation, customer service, marketing, and analytics platforms
Infrastructure	Salesforce-owned data centers (First Party) plus Hyperforce (AWS-based next-generation infrastructure with data residency controls)
US Data Residency	Available via Hyperforce US region data can be configured to remain within US borders
Trust Center	trust.salesforce.com publicly accessible compliance documentation library with 476 active documents
Compliance Program Maturity	Highly mature maintains active certifications across 25+ frameworks with a dedicated trust and compliance team

4. Compliance Certification Review

The following certifications were identified through review of trust.salesforce.com/compliance. All certifications were verified as actively maintained as of May 19, 2026. Relevance ratings

reflect applicability to a government contractor operating under FedRAMP and CMMC 2.0 requirements.

4.1 Government and Defense Certifications

Certification	Status	Relevance to Apex Defense Solutions
FedRAMP High	Confirmed	Highest FedRAMP authorization level authorizes use for the most sensitive federal data. Exceeds the FedRAMP Moderate baseline required for most government contractor use cases. Critical positive finding.
FedRAMP Moderate	Confirmed	Covers broader Salesforce product portfolio. Required baseline for any cloud service processing federal data. Confirmation of both High and Moderate provides flexibility across different program requirements.
DoD IL2	Confirmed	Department of Defense Impact Level 2 covers unclassified DoD information. Relevant for standard DoD contractor communications.
DoD IL4	Confirmed	Impact Level 4 covers Controlled Unclassified Information (CUI). Directly applicable to Apex Defense Solutions' CUI handling obligations. Critical positive finding.
DoD IL5	Confirmed	Impact Level 5 covers National Security Systems and higher sensitivity CUI. Provides headroom for future program requirements.
NIST SP 800-171	Confirmed	Governs protection of CUI in nonfederal systems the foundational framework for CMMC 2.0 Level 2. Salesforce compliance with 800-171 is essential for CUI-capable CRM deployment.
CMMC 2.0	Not Confirmed	CMMC 2.0 certification not explicitly listed on the trust center. Requires direct clarification from Salesforce account team. Note: NIST 800-171 and DoD IL4 compliance substantially addresses CMMC Level 2 requirements but formal CMMC certification status must be verified.
CJIS	Confirmed	Criminal Justice Information Services compliance relevant if future contracts involve law enforcement or criminal justice agencies.

4.2 Security and Privacy Certifications

Certification	Status	Relevance to Apex Defense Solutions
SOC 2 Type II	Confirmed	Covers Security, Availability, Integrity, Confidentiality, and Privacy over a sustained audit period. Type II (vs Type I) means controls were tested over time — the gold standard for SaaS vendor security assurance. Full report requires NDA to recommend requesting as part of contract negotiation.

SOC 1 Type II	Confirmed	Financial reporting controls. Relevant for contract financial data processed in the CRM.
ISO 27001	Confirmed	International information security management system standard. Demonstrates mature ISMS governance framework.
ISO 27017	Confirmed	Cloud-specific security controls based on ISO 27002. Directly applicable to SaaS deployment risk assessment.
ISO 27018	Confirmed	Protection of personally identifiable information in cloud environments. Relevant for federal agency contact data processed in the CRM.
ISO 22301	Confirmed	Business continuity management confirms Salesforce maintains a tested BCM program for operational resilience.
HITRUST	Confirmed	One of the most rigorous enterprise compliance frameworks. Presence demonstrates a mature control environment beyond minimum certification requirements.
CSA STAR	Confirmed	Cloud Security Alliance Security Trust Assurance and Risk registry — independent third-party validation of cloud security controls.
External Pen Tests	Confirmed	Active third-party penetration test summary available on trust center, updated May 19, 2026 (current date). Demonstrates ongoing security validation commitment.
OWASP Top 10 Controls	Confirmed	Salesforce publishes documentation of security controls for each OWASP Top 10 category — demonstrates application security maturity.

5. Risk Domain Assessment

Each risk domain was assessed using a 1-10 scoring scale where 10 represents the lowest risk (strongest controls) and 1 represents the highest risk (weakest controls). Scores are based on publicly available documentation reviewed on trust.salesforce.com. Domains requiring contractual clarification are noted.

Risk Domain	Score	Rationale
Access Controls & IAM	9/10	FedRAMP High authorization requires rigorous identity and access management controls validated by a Third Party Assessment Organization (3PAO). DoD IL4/IL5 adds additional MFA and privileged access requirements.
Data Encryption	9/10	FedRAMP and DoD IL4 mandate FIPS 140-2 validated encryption at rest and in transit. Salesforce compliance with these frameworks confirms encryption standards meet federal requirements.
Data Residency & Sovereignty	8/10	Hyperforce US region provides US-only data residency option critical for CUI handling. However, data residency

		must be explicitly configured at contract time; it is not the default for all Salesforce products.
Incident Response	8/10	FedRAMP authorization requires a documented and tested Incident Response Plan meeting NIST 800-61 standards. SOC 2 Type II independently validates IR controls. Specific IR SLAs not publicly disclosed obtained via contract.
Business Continuity & DR	8/10	ISO 22301 certification and dedicated Resilience/BCP documentation confirm a mature business continuity program. Specific RTO/RPO commitments require contractual negotiation.
Third-Party / Supply Chain Risk	7/10	As a major cloud provider, Salesforce itself has an extensive vendor and sub-processor ecosystem. The sub-processor list should be reviewed as part of contract due diligence. AWS underpins Hyperforce infrastructure.
Availability & SLA	6/10	Salesforce operates a real-time status page with historical incident data. However, specific contractual uptime SLA percentages are not publicly disclosed on the trust center. SLA commitments must be obtained and contractually bound.
CMMC 2.0 Alignment	6/10	NIST 800-171 compliance and DoD IL4 authorization substantially address CMMC Level 2 requirements but formal CMMC 2.0 certification status is not explicitly confirmed by the trust center. Requires direct vendor clarification before CUI processing authorization.
Vulnerability Management	9/10	Active third-party penetration testing with current results (updated May 19, 2026) and OWASP Top 10 security controls documentation demonstrate mature vulnerability management programs.
Privacy & Data Protection	8/10	ISO 27018, GDPR documentation, and Binding Corporate Rules confirm a mature privacy program. Federal privacy requirements under the Privacy Act should be specifically addressed in the Data Processing Agreement.

6. Risk Scoring Summary

6.1 Inherent Risk Assessment

Inherent risk reflects the risk level before considering Salesforce's security controls based solely on the nature of the data being processed and the vendor relationship type.

Risk Factor	Rating	Basis
Data Sensitivity	HIGH	Potential CUI processing in CRM environment triggers elevated inherent risk under CMMC and FedRAMP frameworks

Vendor Access Level	HIGH	SaaS vendor has logical access to all data stored in the CRM platform including potentially sensitive federal contract information
Business Criticality	MEDIUM-HIGH	CRM supports core business development and contract management functions disruption would impact revenue pipeline visibility
Regulatory Exposure	HIGH	Government contractor context triggers FedRAMP, CMMC 2.0, and NIST 800-171 compliance obligations for all CUI-capable vendors
Overall Inherent Risk	HIGH	Combination of data sensitivity, regulatory environment, and vendor access level produces a High inherent risk rating prior to control evaluation

6.2 Residual Risk Assessment

Residual risk reflects the remaining risk level after applying Salesforce's documented security controls and compliance certifications. The strength and breadth of Salesforce's compliance program significantly reduces inherent risk.

Risk Factor	Residual Rating	Control Effectiveness
Data Protection Controls	LOW	FedRAMP High, DoD IL4, NIST 800-171, and SOC 2 Type II collectively validate robust data protection controls
Access Control	LOW	FedRAMP and DoD IL authorizations require 3PAO-validated access controls meeting federal standards
Security Assurance	LOW	Active third-party penetration testing, CSA STAR, and HITRUST provide independent security validation
CMMC Alignment	MEDIUM	Residual uncertainty remains on formal CMMC 2.0 certification status controls likely sufficient but formal confirmation required
Contractual Protections	MEDIUM	SLA commitments and sub-processor controls not publicly confirmed residual risk until contractual terms are reviewed and bound
Overall Residual Risk	LOW-MEDIUM	Strong compliance posture reduces inherent High risk to Low-Medium. Remaining medium risk items are addressable through contract negotiation and CMMC clarification

7. Key Findings

7.1 Positive Findings

- **FedRAMP High Authorization** - Salesforce holds FedRAMP High authorization, the highest federal authorization level, exceeding the FedRAMP Moderate baseline required for most government contractor use cases. This is the single most significant positive finding in this assessment.
- **DoD IL4 and IL5 Authorization** - Salesforce is authorized for DoD Impact Levels 4 and 5, directly covering CUI handling requirements applicable to Apex Defense Solutions' contract obligations.
- **NIST SP 800-171 Compliance** - Formal compliance with the foundational CUI protection framework substantially addresses CMMC 2.0 Level 2 requirements.
- **SOC 2 Type II Certification** - Independent third-party audit of security controls over a sustained period provides the highest level of assurance available for SaaS vendor security validation.
- **Active Third-Party Penetration Testing** - Penetration test results updated as of May 19, 2026 demonstrate ongoing security validation commitment rather than point-in-time compliance.
- **US Data Residency via Hyperforce** - The Hyperforce US region option enables data residency controls that may be required for certain federal contract data handling requirements.
- **Mature Compliance Documentation Library** - 476 actively maintained compliance documents across 25+ frameworks demonstrates an exceptionally mature compliance program compared to typical SaaS vendors.

7.2 Gaps and Items Requiring Clarification

- **CMMC 2.0 Formal Certification Status** - CMMC 2.0 certification is not explicitly confirmed on the trust center. While NIST 800-171 and DoD IL4 substantially address CMMC Level 2 requirements, formal CMMC certification status must be confirmed with the Salesforce account team before authorizing CUI processing in the platform.
- **Uptime SLA Commitments** - Specific contractual SLA percentages are not publicly disclosed. Apex Defense Solutions must negotiate and contractually bind specific uptime, RTO, and RPO commitments before deployment.
- **SOC 2 Report Access** - The full SOC 2 Type II report is not publicly available and requires NDA execution. The report should be reviewed for any exceptions or qualified opinions before final vendor approval.
- **Sub-Processor Inventory** - Salesforce's complete sub-processor list should be reviewed to identify any sub-processors that may handle Apex Defense Solutions data and assess their individual compliance postures.
- **Data Processing Agreement** - A formal DPA addressing CUI handling obligations, federal privacy requirements, breach notification timelines, and data deletion procedures must be executed prior to go-live.

8. Recommendation

RECOMMENDATION	ACCEPT WITH CONDITIONS
-----------------------	-------------------------------

Salesforce is recommended for conditional approval as the CRM platform for Apex Defense Solutions, subject to satisfaction of the following conditions prior to procurement authorization and CUI data onboarding:

- **Condition 1** - CMMC Confirmation: Obtain written confirmation from Salesforce of formal CMMC 2.0 Level 2 certification status or a documented compliance roadmap. If CMMC 2.0 certification is not yet achieved, obtain a written attestation of NIST 800-171 compliance with supporting evidence.
- **Condition 2** - SOC 2 Report Review: Execute NDA and obtain the full SOC 2 Type II report. Review for any exceptions, qualified opinions, or management responses that could indicate control weaknesses relevant to CUI handling.
- **Condition 3** - SLA Negotiation: Negotiate and contractually bind uptime SLA commitments (recommend minimum 99.9% availability), RTO of 4 hours or less, RPO of 1 hour or less, and breach notification within 72 hours consistent with federal requirements.
- **Condition 4** - Data Processing Agreement: Execute a DPA specifically addressing CUI handling obligations, data residency confirmation for US Hyperforce region, sub-processor disclosure requirements, breach notification timelines, and data deletion procedures on contract termination.
- **Condition 5** - Hyperforce US Configuration: Confirm in writing that all Apex Defense Solutions data will be stored and processed exclusively in Hyperforce US region data centers with no cross-border data transfers.
- **Condition 6** - Annual Reassessment: Schedule annual vendor risk reassessment to verify continued compliance certification currency and evaluate any new Salesforce product changes or security incidents that may affect the risk posture.

Salesforce's FedRAMP High authorization, DoD IL4/IL5 authorization, NIST SP 800-171 compliance, and SOC 2 Type II certification collectively represent one of the strongest compliance postures available in the enterprise SaaS market. The identified gaps are addressable through contract negotiation and do not indicate fundamental security deficiencies. Subject to satisfaction of the six conditions above, Salesforce presents an acceptable residual risk for CRM deployment at Apex Defense Solutions.

9. Conclusion

This third-party vendor risk assessment evaluated Salesforce as a CRM platform candidate for Apex Defense Solutions, a fictional government contractor subject to FedRAMP, CMMC 2.0, and NIST SP 800-171 requirements. The assessment was conducted through review of publicly available documentation on trust.salesforce.com including the compliance certification library, security documentation, and availability information.

Salesforce's compliance posture is exceptionally mature relative to typical SaaS vendors. FedRAMP High authorization, DoD IL4/IL5 authorization, NIST SP 800-171 compliance, SOC 2 Type II certification, active third-party penetration testing, and a 476-document compliance library collectively demonstrate a vendor that has made significant, sustained investment in security and compliance directly reducing the risk burden on Apex Defense Solutions as a customer.

The residual risk rating of Low-Medium reflects the strength of Salesforce's documented controls offset by six contractual and administrative items that require resolution before CUI data can be authorized for processing in the platform. None of these items indicate fundamental security weaknesses they represent standard due diligence requirements for any government-sensitive SaaS procurement that a competent legal and security team can resolve through contract negotiation.

The formal recommendation is Accept with Conditions. Procurement may proceed to contract negotiation with the six conditions documented in Section 8 as mandatory prerequisites to data onboarding authorization.

Assessment prepared by: **Bryan Sykes, GRC Analyst** | May 19, 2026 | Apex Defense Solutions | GRC Portfolio Project